

KỊCH BẢN GIÁM SÁT VÀ PHẢN ỨNG SOAR

1. Phát hiện thiết bị lạ truy cập mạng

- Mô tả: Hệ thống phát hiện một thiết bị mới (MAC lạ) vừa kết nối vào mạng và xin cấp IP từ pfSense.
- Cách test: Bật/tắt card mạng trên máy Windows 10 để gửi yêu cầu DHCPREQUEST.
- Kết quả Wazuh: Kích hoạt Rule 100040 (Level 7). Decoder bóc tách thành công địa chỉ MAC và IP cấp phát.
- Hành động SOAR: Telegram báo cáo chi tiết thiết bị lạ kèm địa chỉ MAC. Thông tin được ghi nhận vào Google Sheets để quản lý thiết bị.

2. Tấn công dò quét mật khẩu - Brute Force

- Mô tả: Kẻ tấn công cố gắng đăng nhập vào giao diện quản trị pfSense bằng các tài khoản dự đoán.
- Cách test: Máy Người 1 vào trang Web pfSense, cố tình gõ sai Username/Password liên tục 5 lần.
- Kết quả Wazuh: Kích hoạt Rule 100002 (Level 10). Hệ thống nhận diện được tên User "khachhang" và IP nguồn tấn công.
- Hành động SOAR: Telegram cảnh báo nổ ngay lập tức. n8n ra lệnh cho pfSense đẩy IP tấn công vào Blacklist để khóa truy cập.

3. Phát hiện rà quét cổng mạng - Port Scan

- Mô tả: Hacker sử dụng công cụ chuyên dụng (Nmap) để tìm kiếm các cổng dịch vụ đang mở trên tường lửa.
- Cách test: Dùng máy Kali Linux gõ lệnh `sudo nmap -sS -p 1-1000 <IP_pfsense>`.
- Kết quả Wazuh: Các gói tin bị pfSense chặn sẽ kích hoạt Rule 100019 (Level 3). Khi đạt số lượng lớn, Rule 100020 (Level 12) sẽ bùng nổ.
- Hành động SOAR: Telegram gửi cảnh báo "BÁO ĐỘNG ĐỎ". Hệ thống Active Response thực hiện chặn IP vĩnh viễn trên firewall.

4. Đăng nhập bất thường ngoài giờ hành chính

- Mô tả: Giám sát các tài khoản quản trị đăng nhập thành công vào hệ thống trong khung giờ nhạy cảm (nửa đêm).
- Cách test: Đăng nhập đúng User/Pass vào pfSense trong khoảng thời gian từ 01:00 - 05:00 (hoặc chỉnh lại giờ hệ thống để test).
- Kết quả Wazuh: Rule gốc 100030 (Level 3) ghi nhận đăng nhập , sau đó kích hoạt Rule 100031 (Level 7) do vi phạm khung giờ.
- Hành động SOAR: Telegram báo động về hoạt động bất thường để quản trị viên kiểm tra danh tính người dùng.

5. Phản ứng khẩn cấp với chuỗi hành vi bất thường

- Mô tả: Kịch bản khi một IP thực hiện nhiều hành vi vi phạm liên tiếp trong thời gian ngắn.
- Cách test: Thực hiện quét Nmap đồng thời với việc gõ sai mật khẩu dồn dập.
- Kết quả Wazuh: Kích hoạt Rule 100050 (Level 13) - Mức độ nguy hiểm cực cao.
- Hành động SOAR: Kích hoạt kịch bản CHẶN KHẨN CẤP. Toàn bộ kết nối từ máy tấn công bị ngắt hoàn toàn (Ping timeout). Ghi chú "Kích hoạt chặn khẩn cấp" được đẩy lên Telegram và Google Sheets